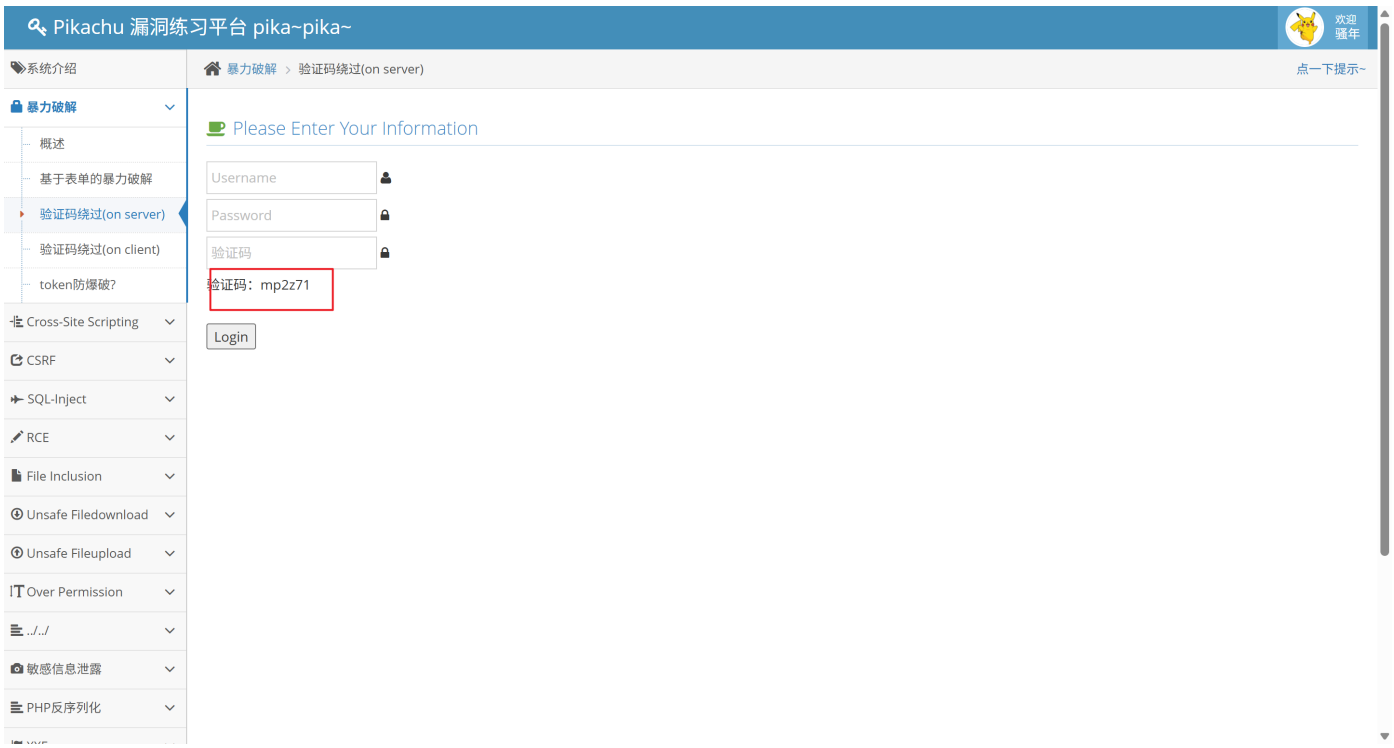
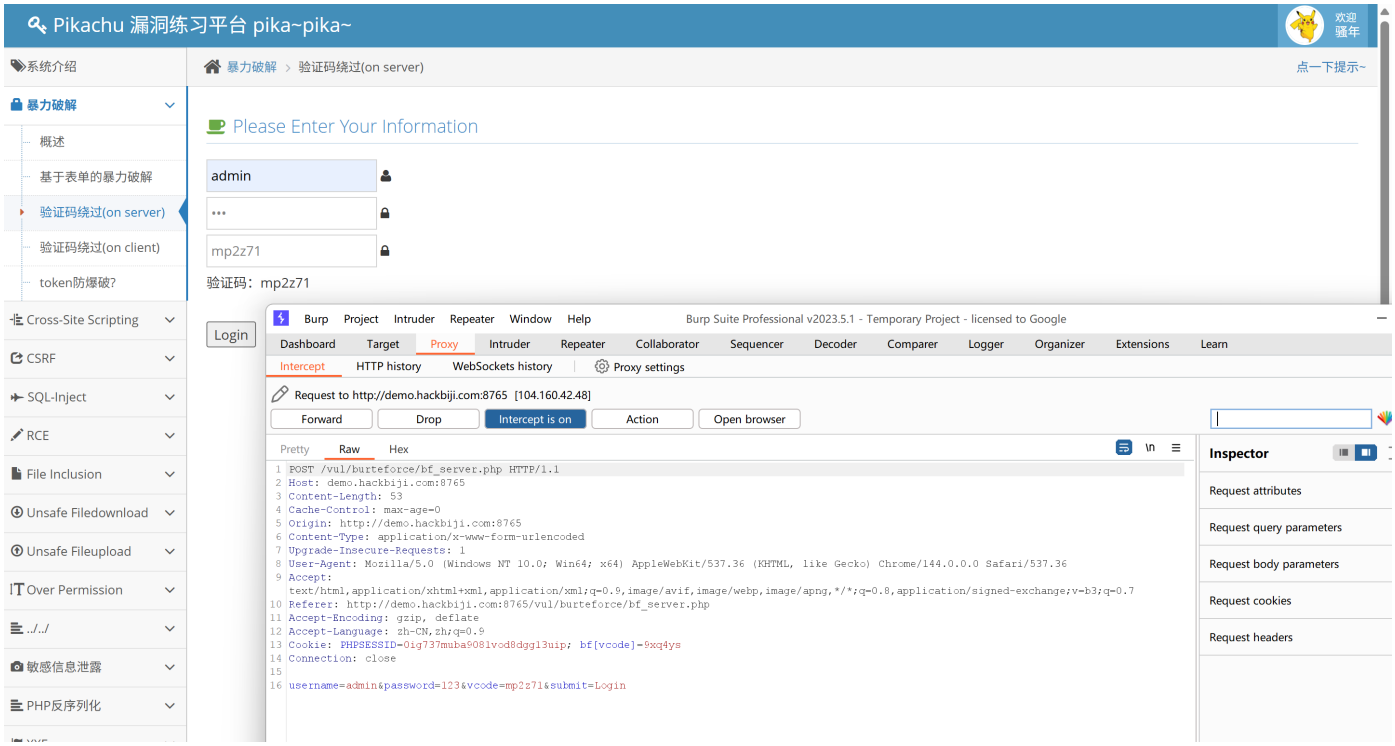
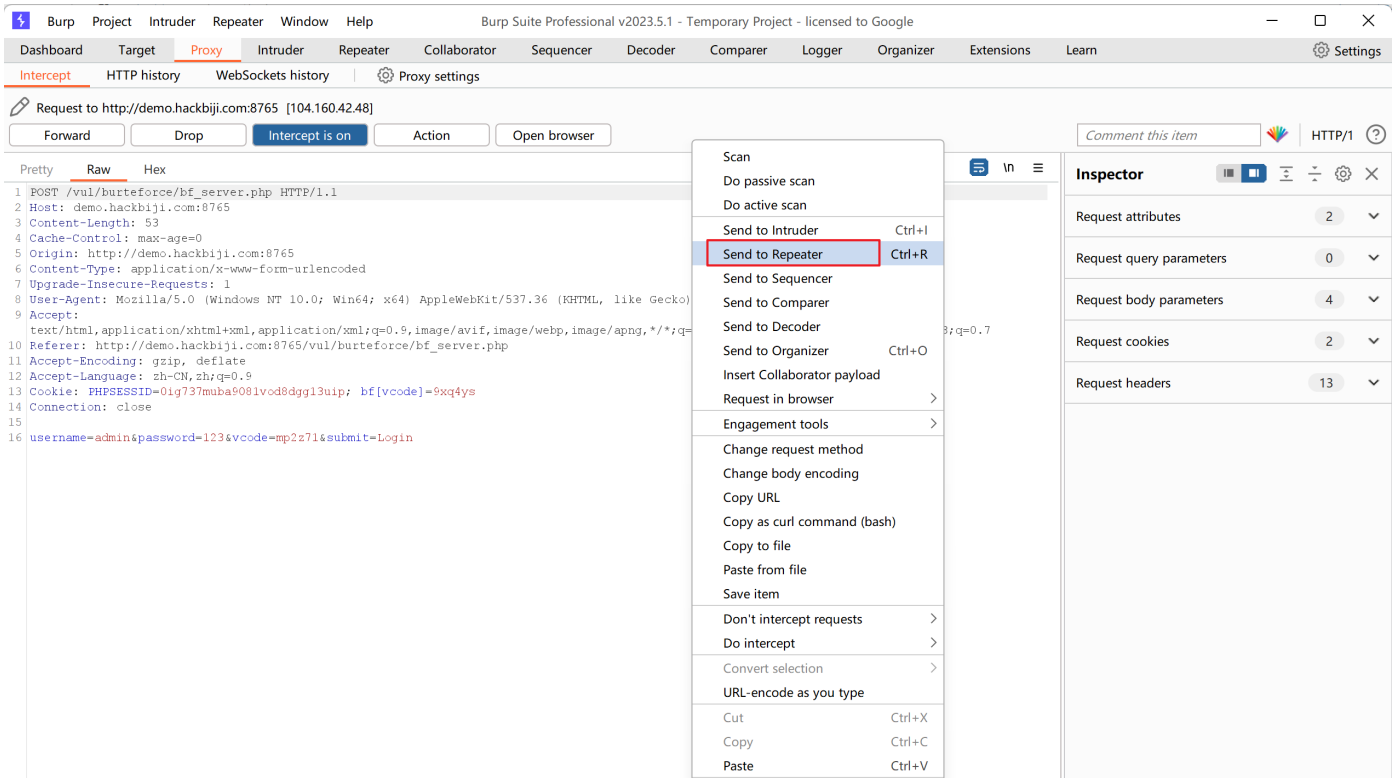
一、验证码绕过 （one server ）

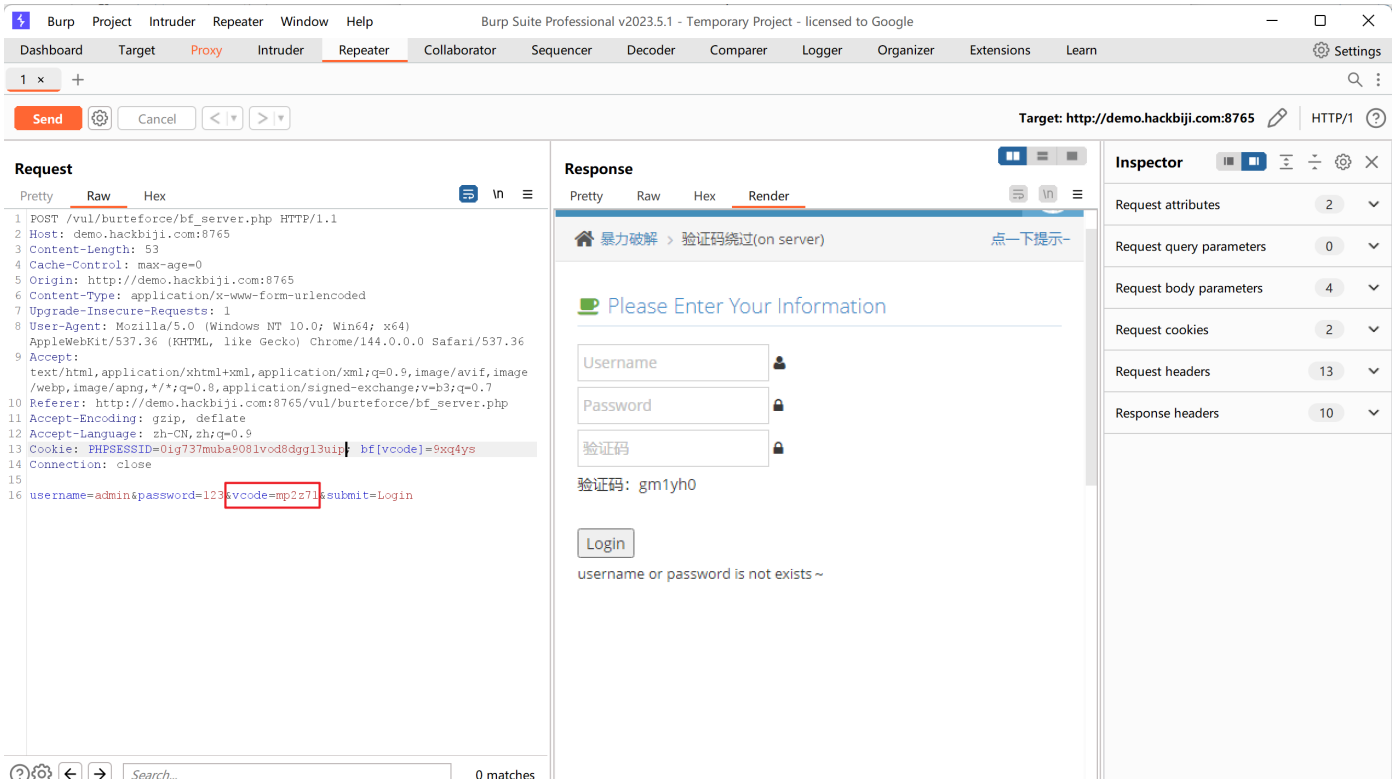
发现多了验证码那一行，再次使用burpsuite进行抓包



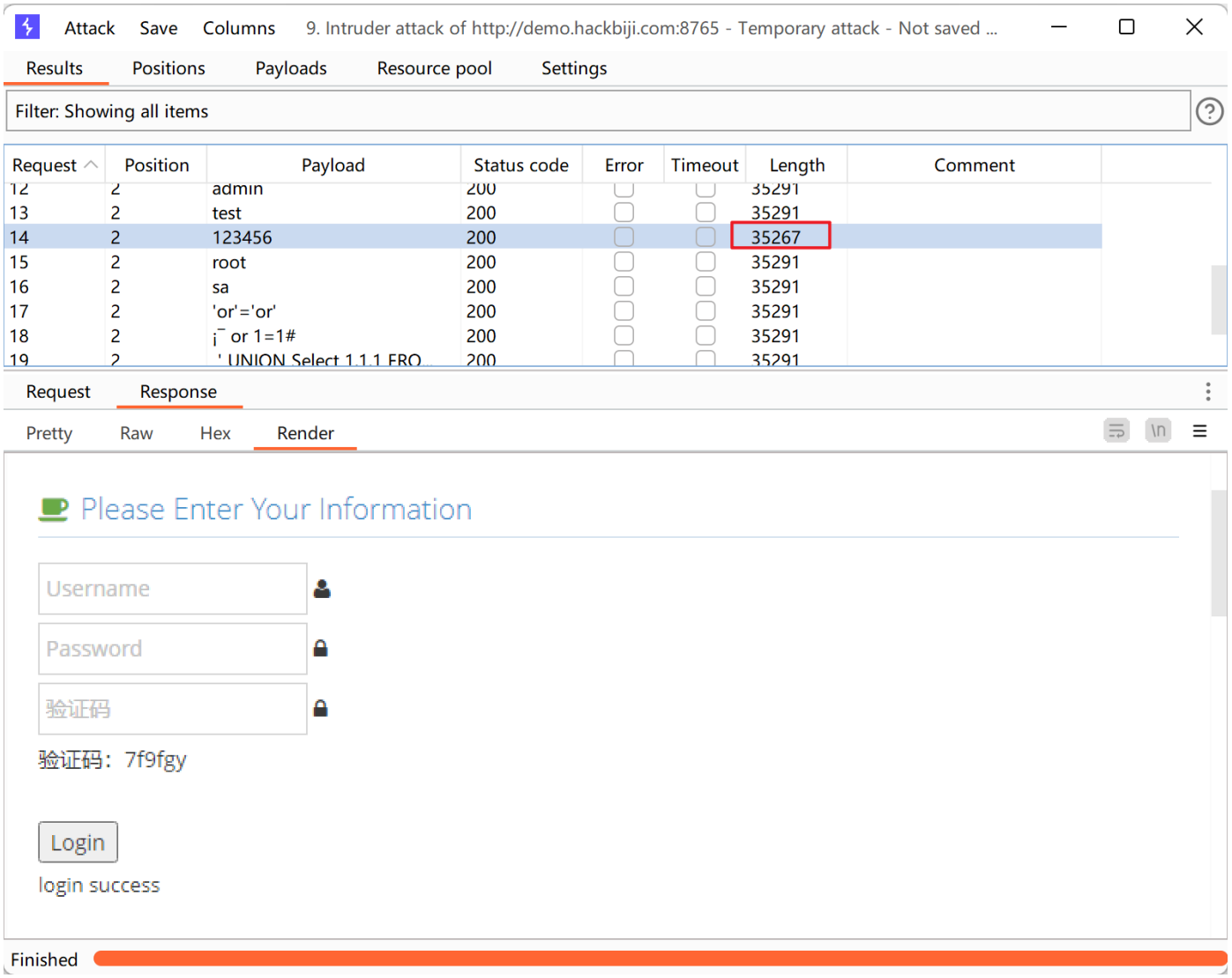




多发送几遍发现验证码没有起到什么作用，于是直接爆破用户名和密码即可

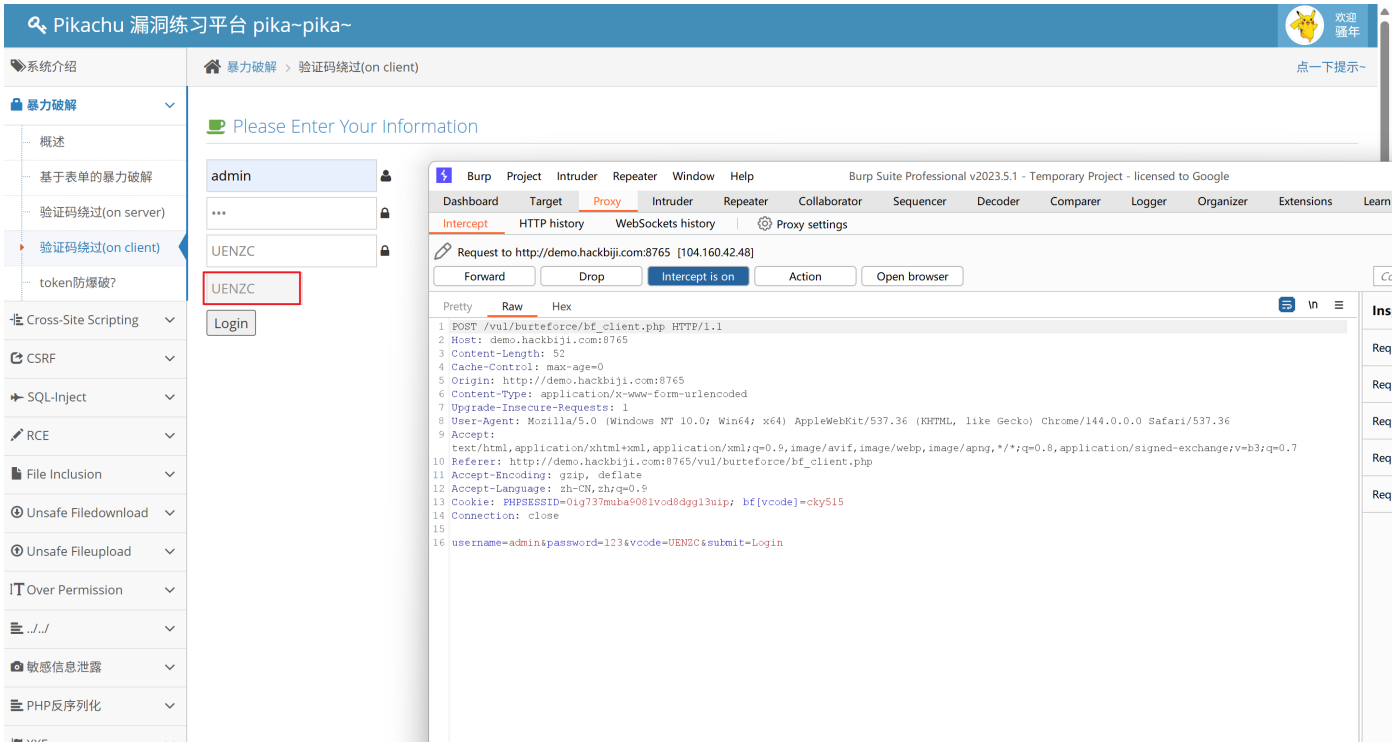


下面就是和表单爆破步骤一样了，最后找长度不一样的就行

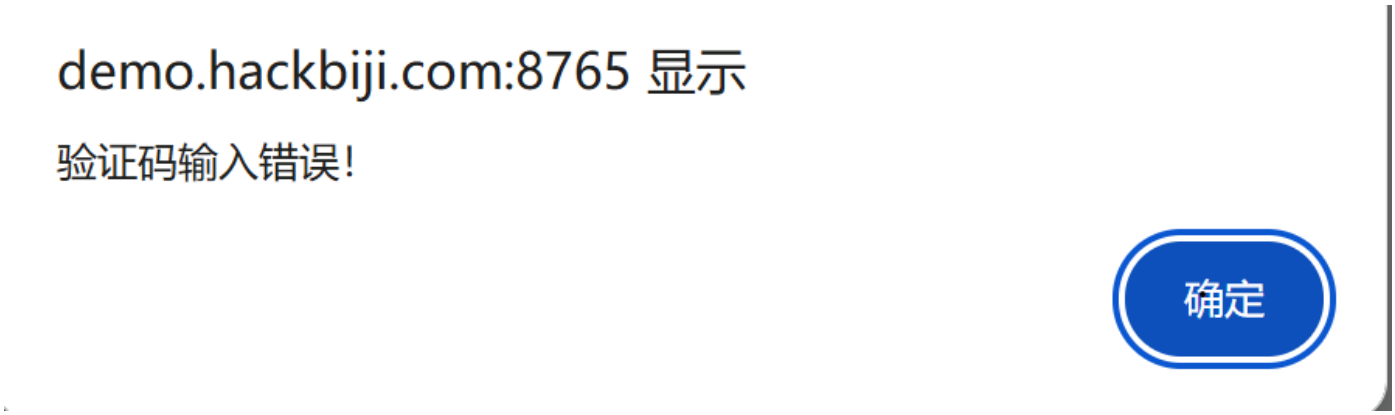


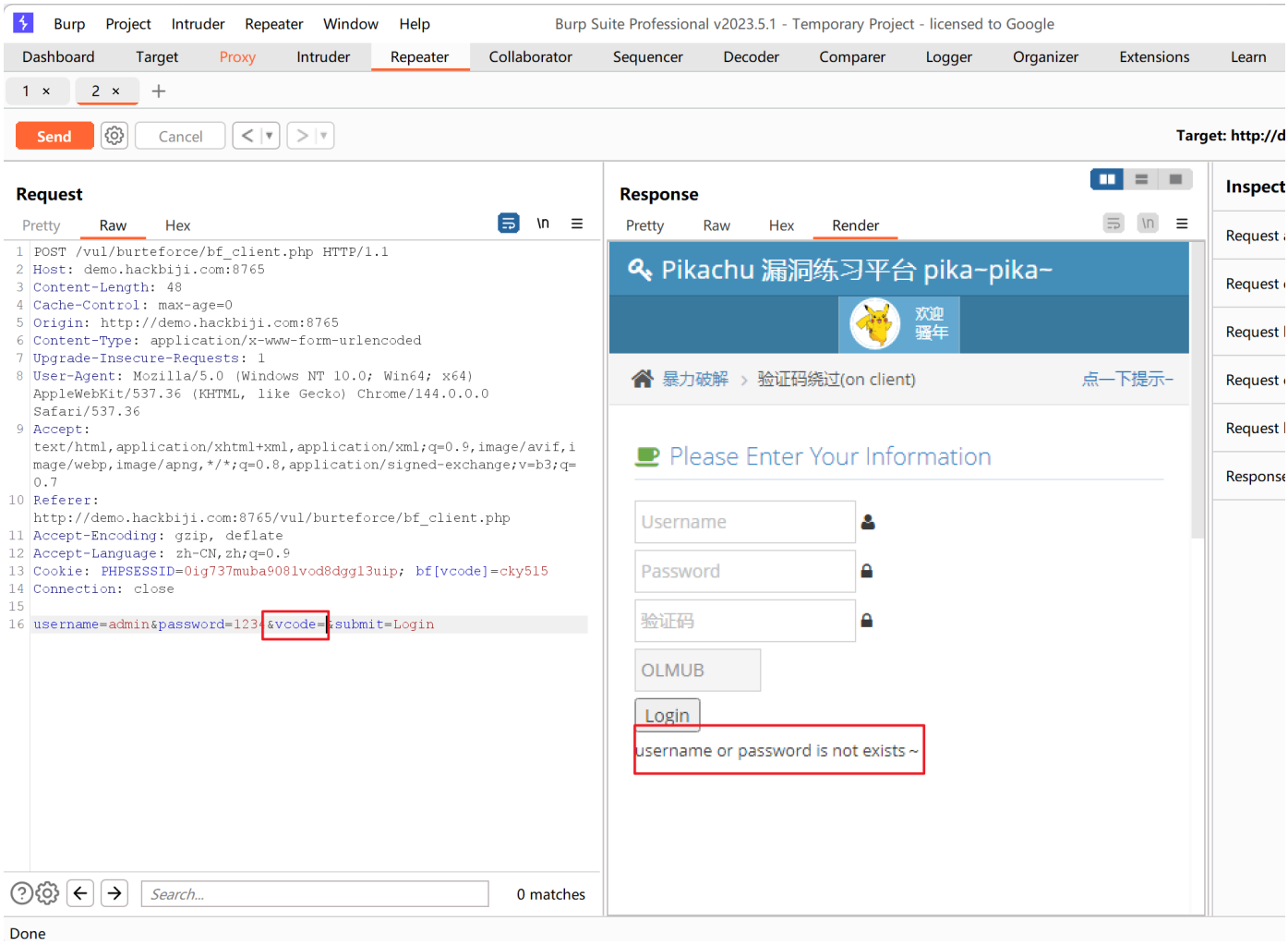
二、验证码绕过（on client）

根据题目提示是在客户端，查看一下js源码



输出错会显示验证码错误，那在发送前把输入验证码那一块删掉试一下





后续一样操作爆破出用户名和密码（后续发现其实禁用 浏览器 js脚本，验证码就不会有显示了也可以实现）

三、token防爆破

3.1、token是什么?

1、Token的引入：Token是在客户端频繁向服务端请求数据，服务端频繁的去数据库查询用户名和密码并进行对比，判断用户名和密码正确与否，并作出相应提示，在这样的背景下，Token便应运而生。

2、Token的定义：Token是服务端生成的一串字符串，以作客户端进行请求的一个令牌，当第一次登录后，服务器生成一个Token便将此Token返回给客户端，以后客户端只需带上这个Token前来请求数据即可，无需再次带上用户名和密码。

3、使用Token的目的：Token的目的是为了减轻服务器的压力，减少频繁的查询数据库，使服务器更加健壮。

3.2、Token认证过程

基于Token的身份验证的过程如下:

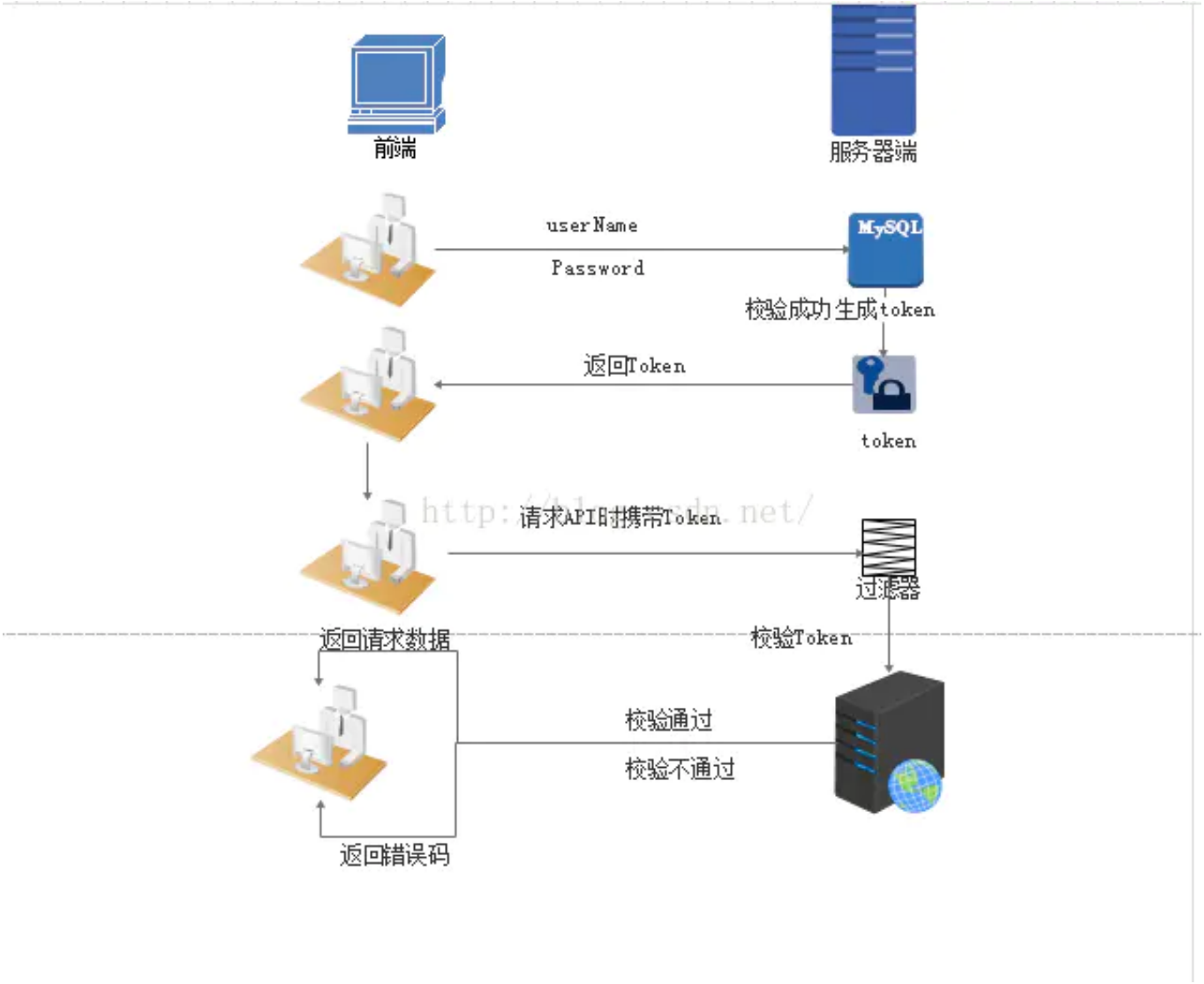
1.用户通过用户名和密码发送请求。

2.服务器端程序验证。

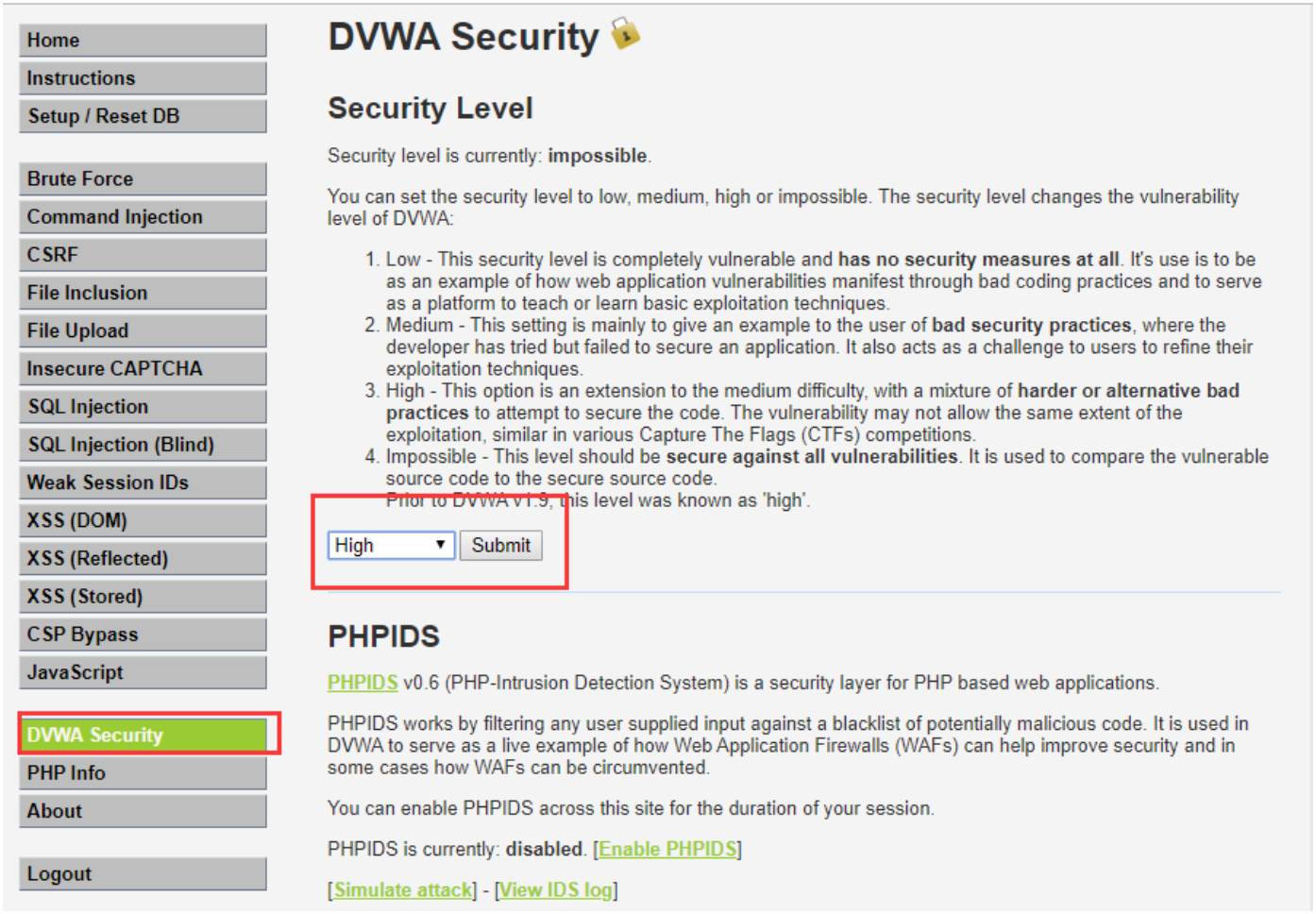
3.服务器端程序返回一个带签名的token 给客户端。

4.客户端储存token,并且每次访问API都携带Token到服务器端的。

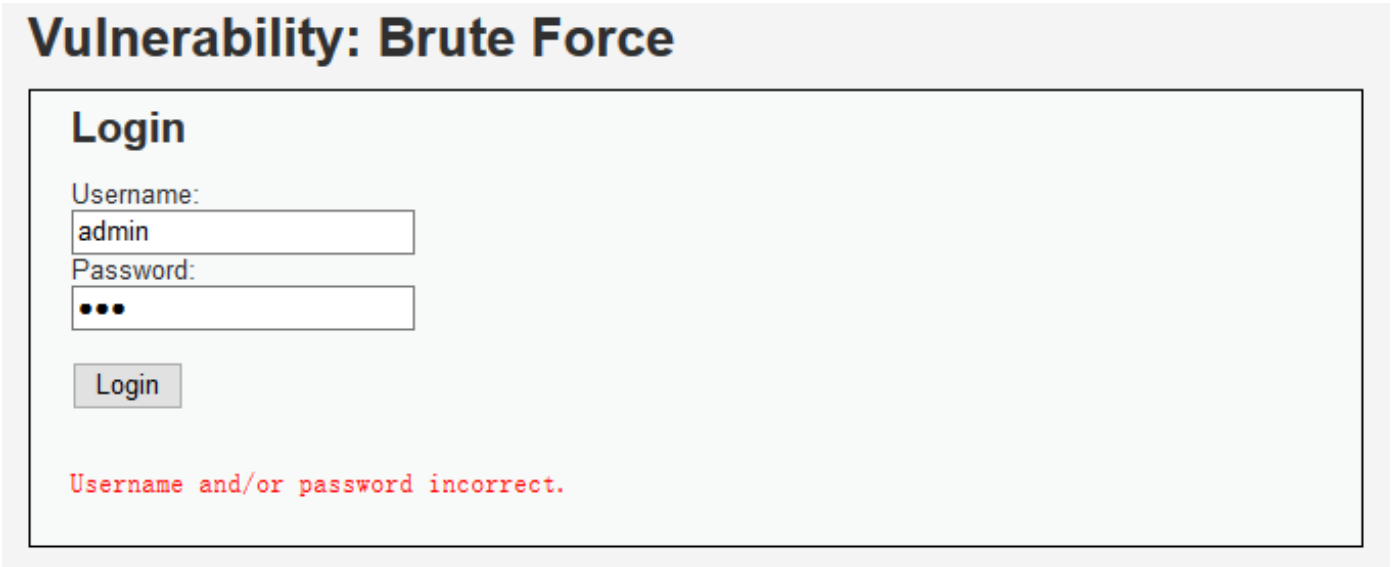
5.服务端验证token，校验成功则返回请求数据，校验失败则返回错误码。

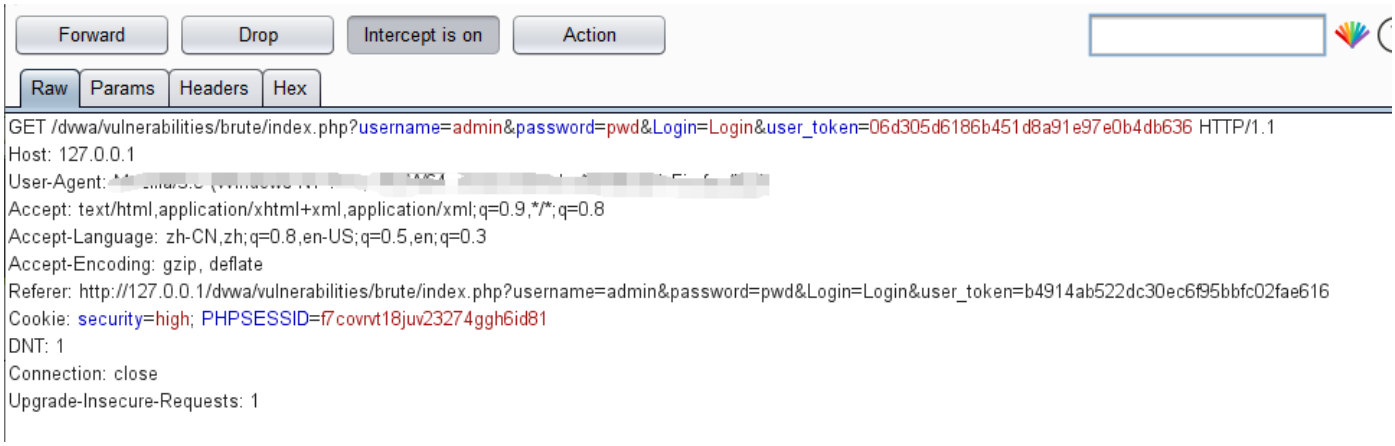


Step1：调整 DVWA 为 high 级别，然后点击进入 Brute Force 。

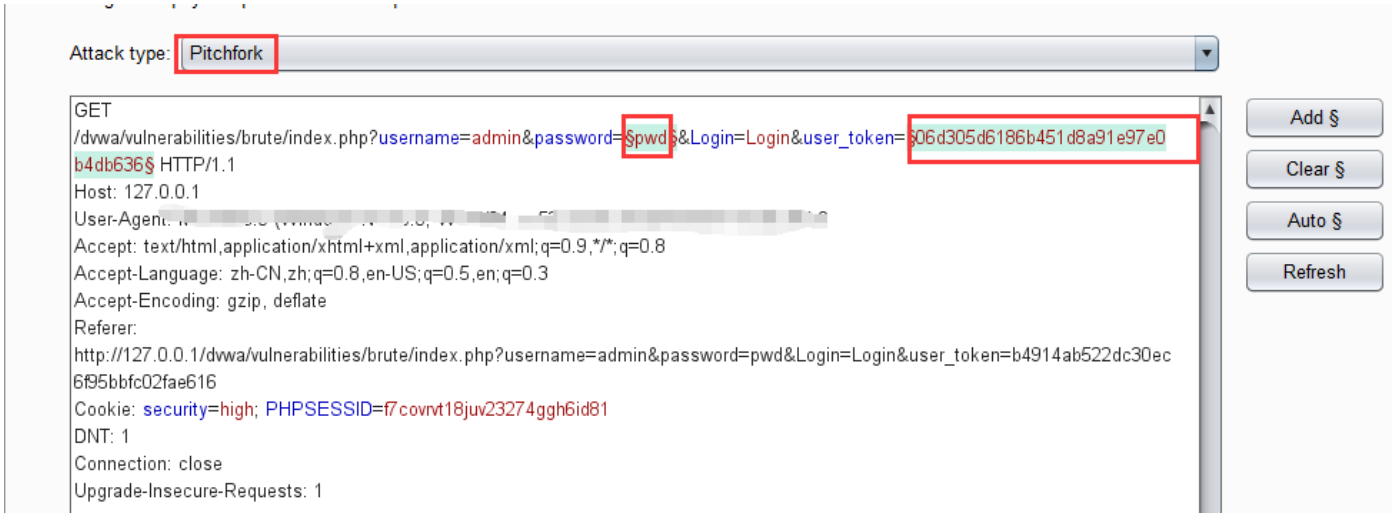


Step2：输入正确的账号，和一个假的密码，使用BP进行拦包。





Step3：Ctrl+i 将拦到的包发送到 Intruder 中，选择需要爆破的密码和 token 值，以及爆破模式选择 Pitchfork ；



Step4：在 Payloads 中，Payload set 1选择使用 Simple list ，将密码字典添加进去；在Payload set 2 中 token 值选择使用 Recursive grep（递归查询：从response中提取数据 user_token 的，然后去替换我们爆破的值）。

Payload Sets

You can define one or more payload sets. The number of payload sets depends on the
payload types are available for each payload set, and each payload type can be custom

Payload set: 1 Payload count: 105

Payload type: Simple list Request count: 105

Payload Options [Simple list]

This payload type lets you configure a simple list of strings that are used as payloads.

Paste
Load ...
Remove
Clear

123
123456789
a123456
123456
a123456789
123.com
1234567890

Add *Enter a new item*

Add from list ...

Payload Sets

You can define one or more payload sets. The number of payload sets depe
payload types are available for each payload set, and each payload type car

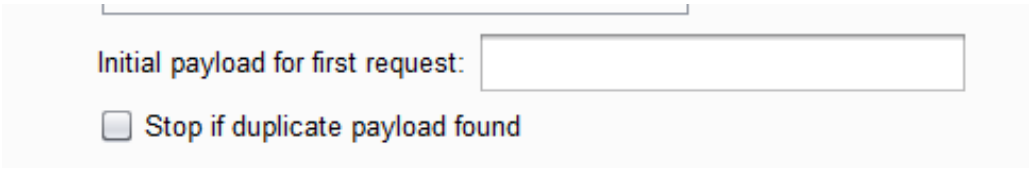
Payload set: 2 Payload count: unknown

Payload type: Recursive grep Request count: 105

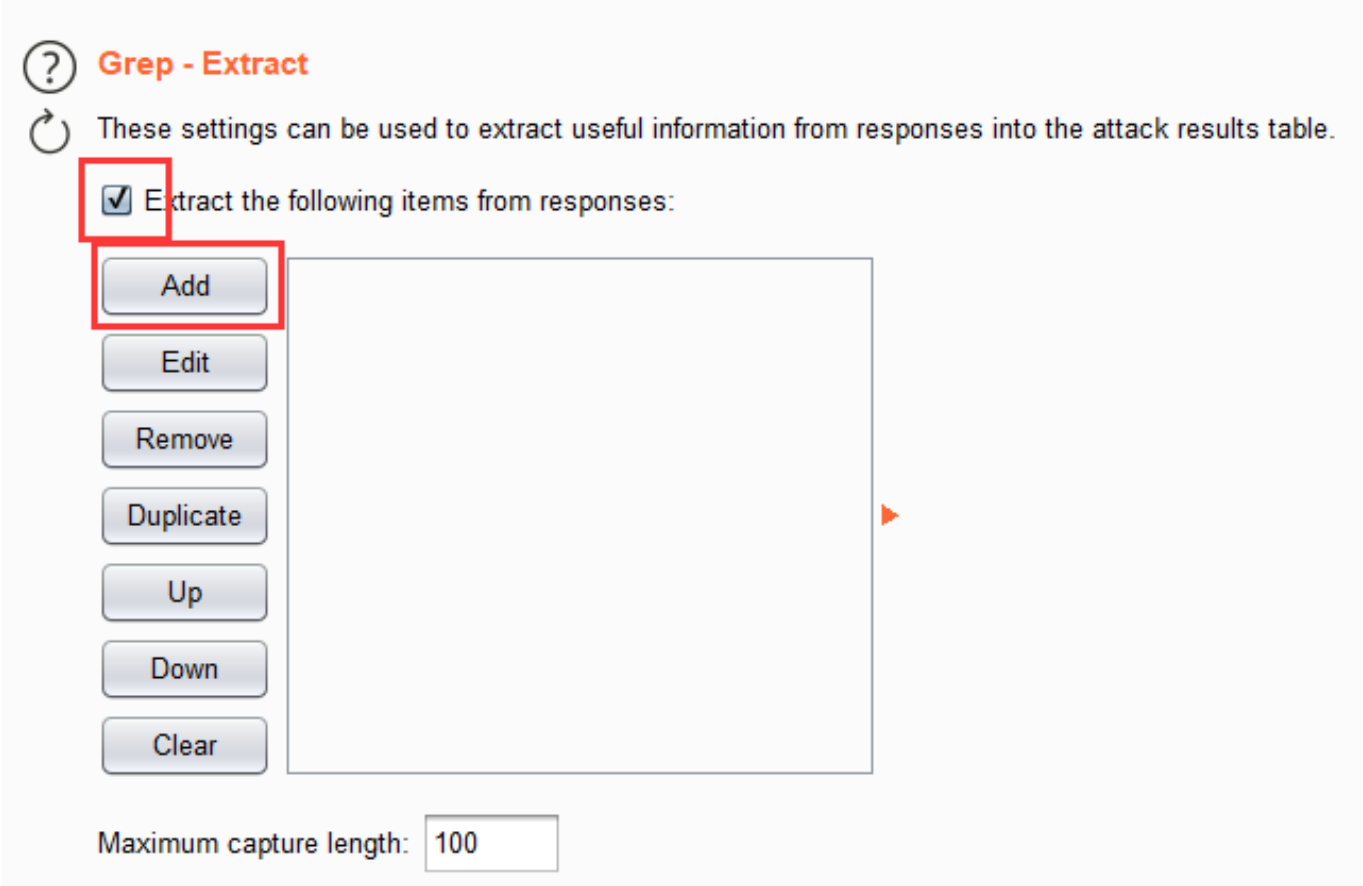
Payload Options [Recursive grep]

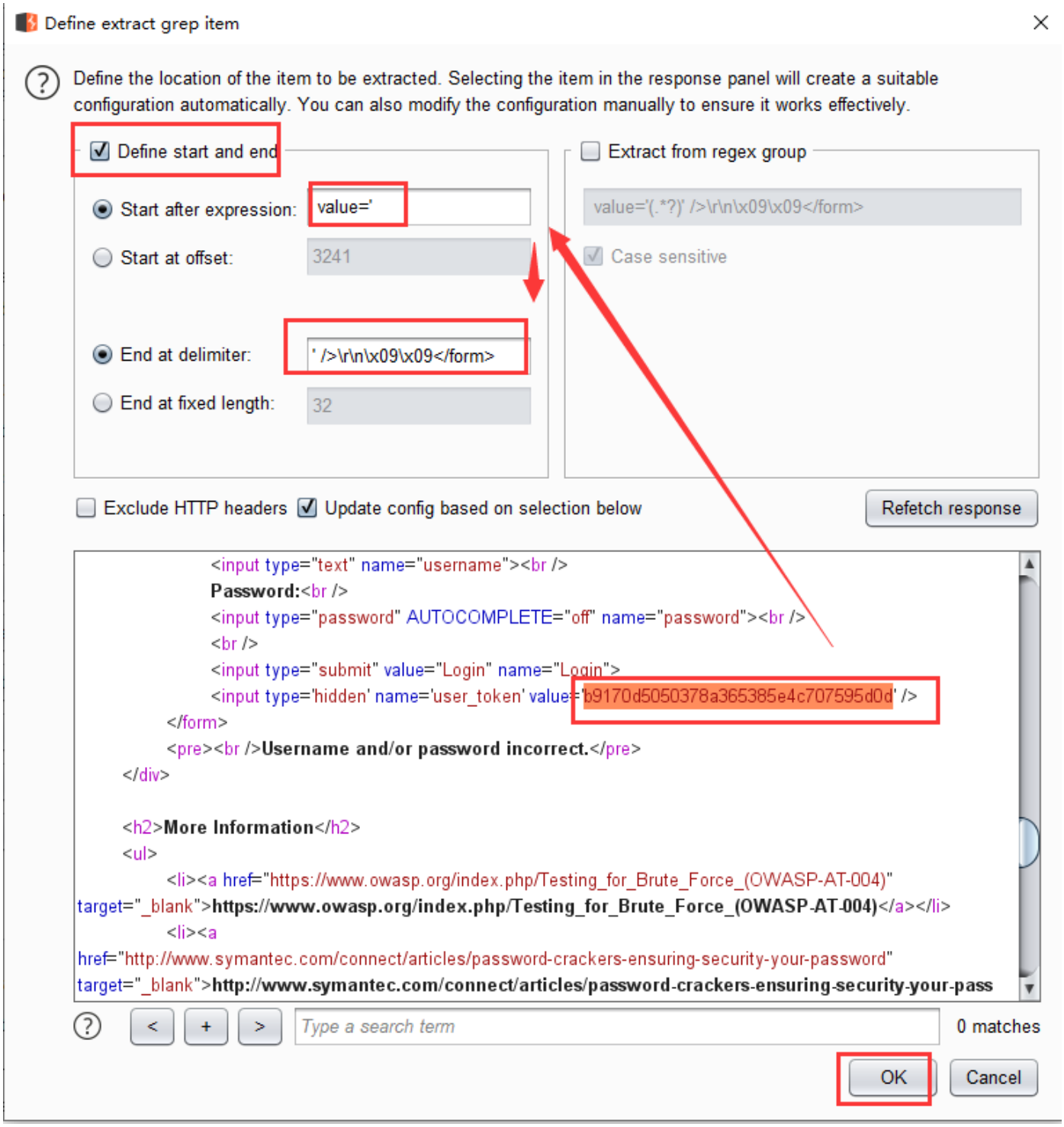
This payload type lets you extract each payload from the response to the pr
work recursively to extract useful data or deliver an exploit. Extract grep item

Select the "extract grep" item from which to derive payloads:



Step4：设置 Options，Request Engine 的线程设置为 1 ，同时需要设置 Grep - Extract ， 点击 Add ， 在弹出的页面点击 Refetch response ， 将其中 token 的值选中，便会自动选择范围；Redirections 选择Always；在Payloads中的“Initial payload for first request”添加初始值。

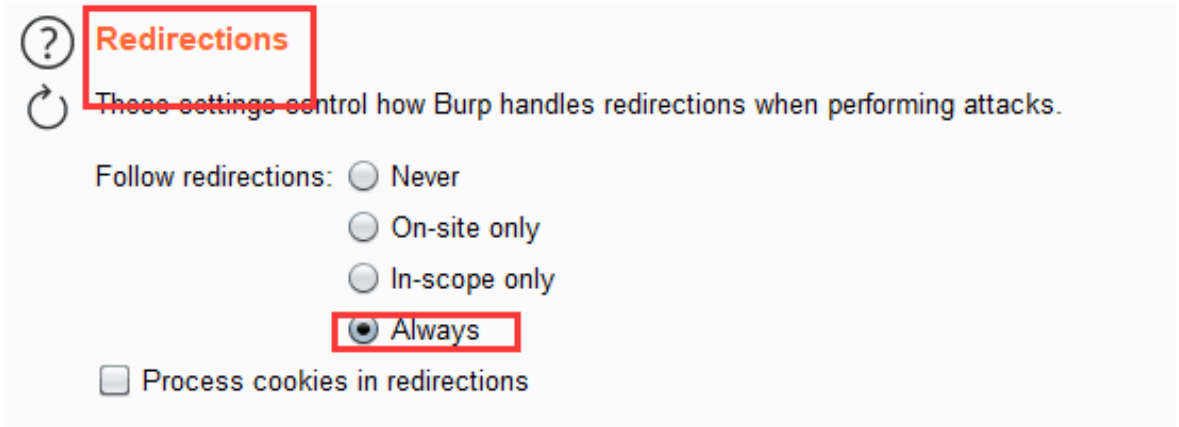


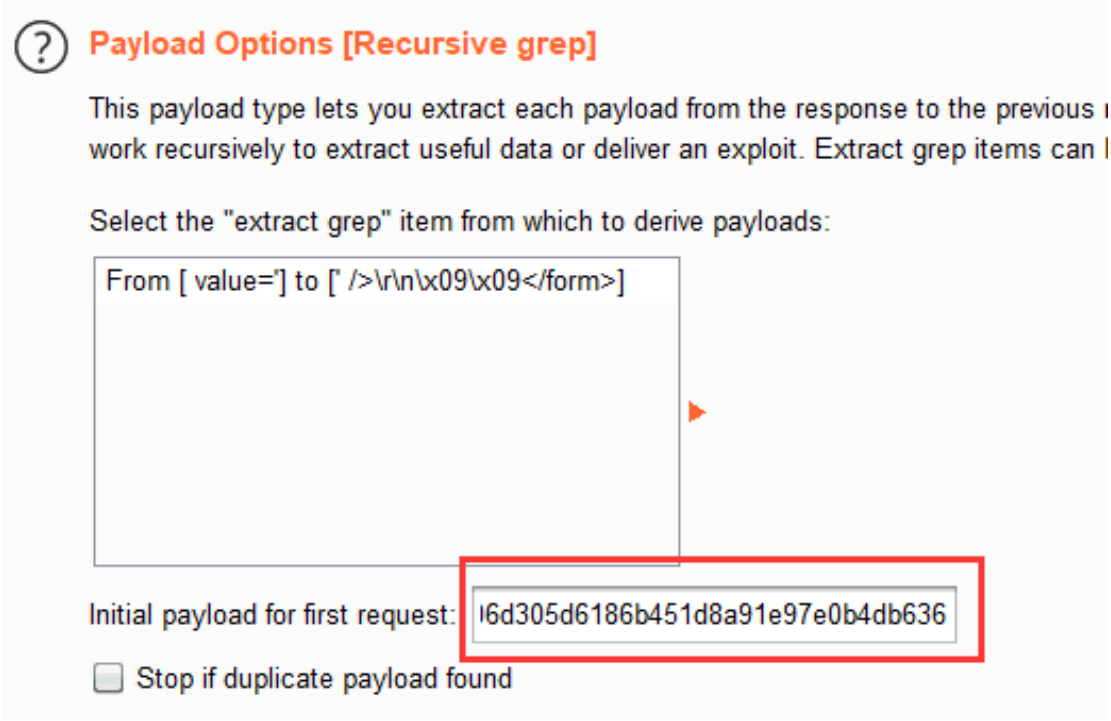

Define extract grep item
Define the location of the item to be extracted. Selecting the item in the response panel will create a suitable configuration automatically. You can also modify the configuration manually to ensure it works effectively.
Define start and end
Start after expression: value='
Start at offset: 3241
End at delimiter: ' />\r\n\x09\x09</form>
End at fixed length: 32
Extract from regex group
value='(.*?)' />\r\n\x09\x09</form>
Case sensitive
Exclude HTTP headers
Update config based on selection below
Refetch response
<input type="text" name="username">
Password:
<input type="password" AUTOCOMPLETE="off" name="password">

<input type="submit" value="Login" name="Login">
<input type='hidden' name='user_token' value='b9170d5050378a365385e4c707595d0d' />
</form>
<pre>
Username and/or password incorrect.</pre>

<h2>More Information</h2>

https://www.owasp.org/index.php/Testing_for_Brute_Force_(OWASP-AT-004)
<a href="http://www.symantec.com/connect/articles/password-crackers-ensuring-security-your-password" target="_blank">http://www.symantec.com/connect/articles/password-crackers-ensuring-security-your-pass
Type a search term
0 matches
OK
Cancel

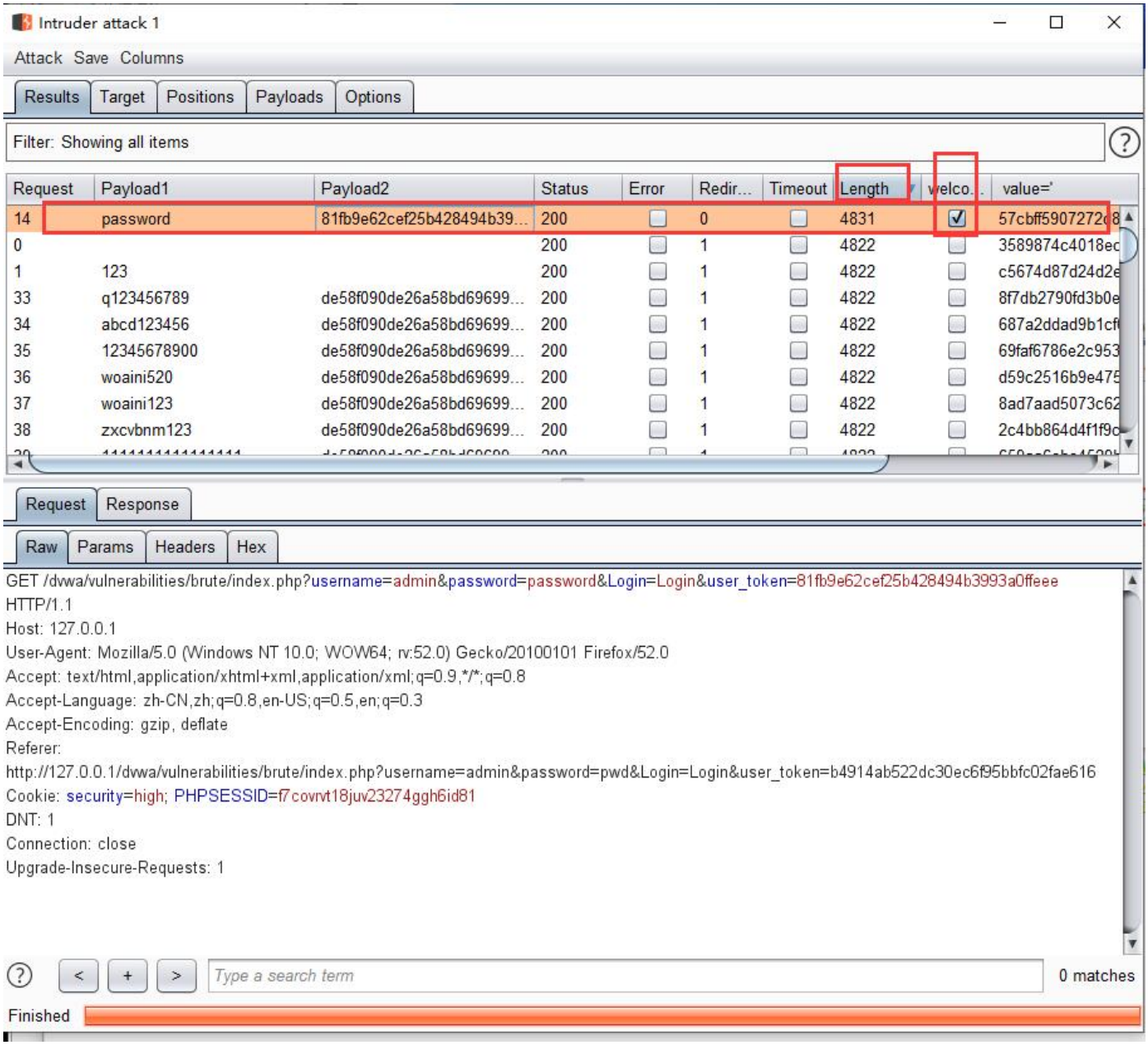

Redirections
These settings control how Burp handles redirections when performing attacks.
Follow redirections:
Never
On-site only
In-scope only
Always
Process cookies in redirections



Step5：点击 Start attack 开始爆破，完成后可以通过对 Length 排序，排在最前面的很可能是正确的密码。

还可以进行如下操作快速找到正确的密码：

Options --> Grep - Match --->添加我们需要的字段


Intruder attack 1
Attack Save Columns
Results Target Positions Payloads Options
Filter: Showing all items
Request Payload1 Payload2 Status Error Redir... Timeout Length welco... value='
14 password 81fb9e62cef25b428494b39... 200 0 4831 57cbff5907272c8
0 200 1 4822 3589874c4018ec
1 123 200 1 4822 c5674d87d24d2e
33 q123456789 de58f090de26a58bd69699... 200 1 4822 8f7db2790fd3b0e
34 abcd123456 de58f090de26a58bd69699... 200 1 4822 687a2ddad9b1cf
35 12345678900 de58f090de26a58bd69699... 200 1 4822 69faf6786e2c953
36 woaini520 de58f090de26a58bd69699... 200 1 4822 d59c2516b9e475
37 woaini123 de58f090de26a58bd69699... 200 1 4822 8ad7aad5073c62
38 zxcvbnm123 de58f090de26a58bd69699... 200 1 4822 2c4bb864d4f1f9c
Request Response
Raw Params Headers Hex
GET /dvwa/vulnerabilities/brute/index.php?username=admin&password=password&Login=Login&user_token=81fb9e62cef25b428494b3993a0ffeee
HTTP/1.1
Host: 127.0.0.1
User-Agent: Mozilla/5.0 (Windows NT 10.0; WOW64; rv:52.0) Gecko/20100101 Firefox/52.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Language: zh-CN,zh;q=0.8,en-US;q=0.5,en;q=0.3
Accept-Encoding: gzip, deflate
Referer:
http://127.0.0.1/dvwa/vulnerabilities/brute/index.php?username=admin&password=pwd&Login=Login&user_token=b4914ab522dc30ec6f95bbfc02fae616
Cookie: security=high; PHPSESSID=f7covrvt18juv23274ggh6id81
DNT: 1
Connection: close
Upgrade-Insecure-Requests: 1
< + >
Type a search term
0 matches
Finished